



**FELLOWPRO AG**

(FELLOWPRO)

# **SOC I TYPE II Report**

For The Period,  
October 1, 2024 to September 30, 2025

Independent Service Auditor's Report on Management's Description of a Service  
Organization's System and on the Suitability of the Design and Operating Effectiveness of the  
Controls



Prepared by: **Accorp Partners**

**SECTION 1**

INDEPENDENT SERVICE AUDITOR'S REPORT

**SECTION 2**

MANAGEMENT ASSERTION

**SECTION 3**

SYSTEM DESCRIPTION

Background and Overview of Services

Principal Service Commitments and System Requirements

**SECTION 4**

DESCRIPTION OF TEST OF CONTROLS AND THEREOF

**SECTION 5**

OTHER INFORMATION PROVIDED BY FELLOWPRO

# SECTION 1

## INDEPENDENT SERVICE AUDITOR'S REPORT

## Independent Service Auditor's Report on FELLOWPRO's Description of Its System and the Suitability of the Design and Operating Effectiveness of Controls

To: Management of FELLOWPRO AG (FELLOWPRO)

### Scope

We have examined management of FELLOWPRO AG's description of its FELLOWPRO system entitled "Management of FELLOWPRO AG's Description of its FELLOWPRO system," for "DocBits - An AI-powered, cloud-based platform for intelligent document processing (IDP) that automates data extraction, classification, and workflow for enterprises" throughout the period October 1, 2024 to September 30, 2025 (description) for user entities of the system during October 1, 2024 to September 30, 2025, and their auditors who audit and report on such user entities' financial statements or internal control over financial statement reporting and have a sufficient understanding to consider it, along with other information, including information about controls implemented by subservice organizations and user entities of the system themselves when assessing the risks of material misstatement of user entities' financial statements.

FELLOWPRO uses Digital Ocean as a subservice organization for data center services. The description includes only the control objectives and related controls of FELLOWPRO and excludes the control objectives and related controls of the subservice organization. The description also indicates that certain control objectives specified by FELLOWPRO can be achieved only if complementary subservice organization controls assumed in the design of FELLOWPRO's controls are suitably designed and operating effectively, along with the related controls at FELLOWPRO. Our examination did not extend to controls of the subservice organization and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

The Description also indicates that FELLOWPRO's controls can provide reasonable assurance that certain service commitments and system requirements can be achieved only if complementary user entity controls assumed in the design of FELLOWPRO's controls are suitably designed and operating effectively, along with related controls at the service organization. Our examination did not extend to such complementary user entity controls and we have not evaluated the suitability of the design or operating effectiveness of such complementary user entity controls.

### Service organization's responsibilities

In Management Assertion, Section 2, FELLOWPRO has provided an assertion about the fairness of the presentation of the description and suitability of the design and operating effectiveness of the controls to achieve the related control objectives stated in the description. Management of FELLOWPRO AG is responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion, providing the services covered by the description, specifying the control objectives and stating them in the description, identifying the risks that threaten the achievement of the control objectives, selecting the criteria stated in the assertion, and designing, implementing, and documenting controls that are suitably designed and operating effectively to achieve the related control objectives stated in the description.

### Service auditor's responsibilities

Our responsibility is to express an opinion on the fairness of the presentation of the description and on the suitability of the design and operating effectiveness of the controls to achieve the related control objectives stated in the description, based on our examination.

Our examination was conducted in accordance with attestation standards established by the AICPA. Those standards require that we plan and perform the examination to obtain reasonable assurance about whether, in all material respects, based on the criteria in management's assertion, the description is fairly presented and the controls were suitably designed and operating effectively to achieve the related control objectives stated in the description throughout the period October 1, 2024 to September 30, 2025. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of controls involves—

- performing procedures to obtain evidence about the fairness of the presentation of the description and the suitability of the design and operating effectiveness of the controls to achieve the related control objectives stated in the description, based on the criteria in management's assertion.
- assessing the risks that the description is not fairly presented and that the controls were not suitably designed or operating effectively to achieve the related control objectives stated in the description.
- testing the operating effectiveness of those controls that management considers necessary to provide reasonable assurance that the related control objectives stated in the description were achieved.
- evaluating the overall presentation of the description, suitability of the control objectives stated in the description, and suitability of the criteria specified by the service organization in its assertion.
- We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements related to the examination engagement.

### **Inherent limitations**

The description is prepared to meet the common needs of a broad range of user entities and their auditors who audit and report on user entities' financial statements and may not, therefore, include every aspect of the system that each individual user entity may consider important in its own particular environment. Because of their nature, controls at a service organization may not prevent, or detect and correct, all misstatements in processing or reporting transactions. Also, the projection to the future of any evaluation of the fairness of the presentation of the description, or conclusions about the suitability of the design or operating effectiveness of the controls to achieve the related control objectives, is subject to the risk that controls at a service organization may become ineffective.

### **Description of tests of controls**

The specific controls tested and the nature, timing, and results of those tests are listed in Section 4 of our report titled "Independent Service Auditors' Description of Test of Controls and Results".

### **Opinion**

In our opinion, in all material respects, based on the criteria described in management of FELLOWPRO AG's assertion—

- a. the description fairly presents the FELLOWPRO system that was designed and implemented throughout the period October 1, 2024 to September 30, 2025.
- b. the controls related to the control objectives stated in the description were suitably designed to provide reasonable assurance that the control objectives would be achieved if the controls operated effectively throughout the period October 1, 2024 to September 30, 2025 and subservice organizations applied the complementary subservice organization controls assumed in the design of FELLOWPRO's controls throughout the period October 1, 2024 to September 30, 2025.
- c. the controls operated effectively to provide reasonable assurance that the control objectives stated in the description were achieved throughout the period October 1, 2024 to September 30, 2025 if complementary subservice organization controls assumed in the design of FELLOWPRO's controls operated effectively throughout the period October 1, 2024 to September 30, 2025.

**Restricted use**

This report, including the description of tests of controls and results thereof in section 4 of this report, is intended solely for the information and use of FELLOWPRO, user entities of FELLOWPRO AG's (FELLOWPRO) system during some or all of the period October 1, 2024 to September 30, 2025, and their auditors who audit and report on such user entities' financial statements or internal control over financial reporting and have a sufficient understanding to consider it, along with other information, including information about controls implemented by user entities themselves, when assessing the risks of material misstatement of user entities' financial statements. This report is not intended to be, and should not be, used by anyone other than these specified parties.

*Accorp Partners CPA LLC*

**Accorp Partners CPA LLC**

**License No.: PAC-FIRM-LIC-47383**

**Kalispell, Montana**

**February 26, 2026**

## SECTION 2

### MANAGEMENT ASSERTION

## Management of FELLOWPRO AG Assertion

We have prepared the description of FELLOWPRO AG's (FELLOWPRO) system entitled "FELLOWPRO AG's Description of its FELLOWPRO system," for "DocBits - An AI-powered, cloud-based platform for intelligent document processing (IDP) that automates data extraction, classification, and workflow for enterprises" throughout the period October 1, 2024 to September 30, 2025 (description) for user entities of the system during some or all of the period October 1, 2024 to September 30, 2025, and their auditors who audit and report on such user entities' financial statements or internal control over financial statement reporting and have a sufficient understanding to consider it, along with other information, including information about controls implemented by subservice organizations and user entities of the system themselves when assessing the risks of material misstatement of user entities' financial statements.

FELLOWPRO uses Digital Ocean as a subservice organization for data center services. The description includes only the control objectives and related controls of FELLOWPRO and excludes the control objectives and related controls of the subservice organization. The description also indicates that certain control objectives specified in the description can be achieved only if complementary subservice organization controls assumed in the design of our controls are suitably designed and operating effectively, along with the related controls. The description does not extend to controls of the subservice organization.

The description indicates that certain control objectives specified in the description can be achieved only if complementary user entity controls assumed in the design of FELLOWPRO's controls are suitably designed and operating effectively, along with related controls at the service organization. The description does not extend to controls of the user entities.

We confirm, to the best of our knowledge and belief, that:

1) The description fairly presents the FELLOWPRO system made available to user entities of the system during some or all of the period October 1, 2024 to September 30, 2025 for processing user entities' transaction throughout the period as it relates to controls that are likely to be relevant to user entities' internal control over financial reporting. The criteria we used in making this assertion were that the description,

- a. Presents how the system made available to user entities of the system was designed and implemented to process relevant user entity transactions, including, if applicable:
  - I. The types of services provided, including, as appropriate, the classes of transactions processed.
  - II. The procedures, within both automated and manual systems, by which those services are provided, including, as appropriate, procedures by which transactions are initiated, authorized, recorded, processed, corrected as necessary, and transferred to the reports and other information prepared for user entities of the system.
  - III. The information used in the performance of the procedures including, if applicable, related accounting records, whether electronic or manual, and supporting information involved in initiating, authorizing, recording, processing, and reporting transactions; this includes the correction of incorrect information and how information is transferred to the reports and other information prepared for user entities.
  - IV. How the system captures and addresses significant events and conditions other than transactions.
  - V. The process used to prepare reports and other information for user entities.
  - VI. The services performed by a subservice organization, if any, including whether the carve-out method or the inclusive method has been used in relation to them.
  - VII. The specified control objectives and controls designed to achieve those objectives including, as applicable, complementary user entity controls and complementary subservice organization controls assumed in the design of the controls.
  - VIII. Other aspects of our control environment, risk assessment process, information and communications (including the related business processes), control activities, and monitoring



activities that are relevant to the services provided.

- b. Includes relevant details of changes to the FELLOWPRO system during the period covered by the description.
- c. Does not omit or distort information relevant to the system, while acknowledging that the description is prepared to meet the common needs of a broad range of user entities of the system and their user auditors and may not, therefore, include every aspect of the FELLOWPRO system that each individual user entity of the system and its auditor may consider important in its own particular environment.

2) The controls related to the control objectives stated in the description were suitably designed and operating effectively throughout the period October 1, 2024 to September 30, 2025 to achieve those control objectives if subservice organizations and user entities applied the complementary controls assumed in the design of FELLOWPRO's controls throughout the period October 1, 2024 to September 30, 2025. The criteria we used in making this assertion were that:

- a. The risks that threaten the achievement of the control objectives stated in the description have been identified by management.
- b. The controls identified in the description would, if operating effectively, provide reasonable assurance that those risks would not prevent the control objectives stated in the description from being achieved.
- c. The controls were consistently applied as designed, including whether manual controls were applied by individuals who have the appropriate competence and authority.

Sincerely,

*Daniel Jordau*

Daniel Jordan  
CTO/CISO

## SECTION 3

### SYSTEM DESCRIPTION

# Background and Overview of Services

## Background and Description of Services provided

FELLOWPRO (FELLOWPRO AG) is a German tech company specializing in Digital Transformation, focusing on CRM, AI, Data Tech, and IoT to automate business processes, especially document management and IDP solutions via their DocBits platform, helping companies integrate solutions like SugarCRM and Infor for data-driven growth and efficiency. They offer consulting, implementation, and custom app development, working across various industries to create smart, integrated workflows.

## Significant Changes during the Review Period

No significant changes have occurred to the services provided to user entities during the audit period.

## Subservice Organizations

FELLOWPRO utilizes the following subservice providers for data center services that are not included within the scope of this examination. However, FELLOWPRO's responsibilities for the applications and services run at these cloud services are covered as part of the audit and in scope. The responsibility matrix is defined as part of the SLA and agreements with these sub-service organizations.

### Digital Ocean

Digital Ocean is a SOC 2 and SOC 3 attested organization.

The Criteria that relate to controls at the subservice organizations included all criteria related to the control objectives of Security and Availability. The types of controls that are necessary to meet the control objectives and related criteria, either alone or in combination with controls at FELLOWPRO include:

- The system is protected against unauthorized access (both physical and logical).
- The system is available for operation and use and in the capacities as committed or agreed.
- Policies and procedures exist related to security and availability and are implemented and followed.

## Principal Service Commitments and System Requirements

FELLOWPRO designs its processes and procedures related to the System to meet its objectives. Those objectives are based on the service commitments that FELLOWPRO makes to user entities, the laws and regulations that govern the provision of products and services to its clients, and the financial, operational, and compliance requirements that FELLOWPRO has established for the services. Security commitments to user entities are documented and communicated in customer agreements, as well as in the description of the service offering provided online.

FELLOWPRO establishes operational requirements that support the achievement of security commitments, relevant laws and regulations, and other system requirements. Such requirements are communicated in FELLOWPRO's system policies and procedures, system design documentation, and contracts with customers.

Information security policies define an organization-wide approach to how systems and data are protected. These include policies around how the service is designed and developed, how the system is operated, how the internal business systems and networks are managed and how employees are hired and trained. In addition to these policies, standard operating procedures have been documented on how to carry out specific manual and automated processes required in the operation and development of the System.

## Components of the System

The System is comprised of the following components:

- Infrastructure including the physical structures, Information Technology (IT), and other hardware.
- Software including application programs and IT system software that support application programs.
- People including executives, sales and marketing, client services, product support, information processing, software development, IT, Finance, and Human resources.
- Procedures (automated and manual).
- Data including transaction streams, files, databases, tables, and output used or processed by the system.

The System boundaries include the applications, databases, and infrastructure required to directly support the services provided to FELLOWPRO's clients. Any infrastructure, software, people, procedures, and data that indirectly support the services provided to FELLOWPRO's customers are not included within the boundaries of its system.

## Boundaries of the System

The specific products, services, and locations that are included in the scope of the report are given below. All other products, services, and locations are not included.

| Products and Services in Scope                                              |                                          |
|-----------------------------------------------------------------------------|------------------------------------------|
| <b>Products</b> <ul style="list-style-type: none"> <li>• DocBits</li> </ul> |                                          |
| Geographic Locations in Scope                                               |                                          |
| Germany                                                                     | Anzinger Str. 21 A, 85586 Poing, Germany |

All the above material activities and operations in scope are performed from the above office location. Unless otherwise mentioned, the description and related controls apply only to the location covered by the report.

## Description of Control Environment, Control Activities, Risk Assessment, Monitoring and Information, and Communication

### Control Environment

FELLOWPRO's internal control environment reflects the overall attitude, awareness, and actions of management concerning the importance of controls, and the emphasis given to controls in the Company's policies, procedures, methods, and organizational structure.

The Chief Executive Officer, the Senior Management Team and all employees are committed to establishing and operating an effective Information Security Management System in accordance with its strategic business objectives. The Management at FELLOWPRO is committed to the Information Security Management System, and ensures that IT policies are communicated, understood, implemented and maintained at all levels of the organization and regularly reviewed for continual suitability.

### Integrity and Ethical Values

FELLOWPRO requires directors, officers, and employees to observe high standards of business and personal ethics in conducting their duties and responsibilities. Honesty and integrity are core principles of the Company, and all employees are expected to fulfill their responsibilities based on these principles and comply with all applicable laws and regulations. FELLOWPRO promotes an environment of open communication and has

created an environment where employees are protected from any kind of retaliation should a good-faith report of an ethics violation occur. Executive management has the exclusive responsibility to investigate all reported violations and to take corrective action when warranted.

## Board of Directors

Business activities at FELLOWPRO are under the direction of the Board of Directors.

## Management's Philosophy and Operating Style

The Executive Management team at FELLOWPRO assesses risks prior to venturing into business ventures and relationships. The size of FELLOWPRO enables the executive management team to interact with operating management on a daily basis.

## Risk Management and Risk Assessment

Risk assessments are performed annually to identify current risk levels, with recommendations to minimize those risks that are determined to pose an unacceptable level of risk to FELLOWPRO. As part of this process, security threats are identified and the risk from these threats is formally assessed.

FELLOWPRO has operationalized a risk assessment process to identify and manage risks that could adversely affect their ability to provide reliable processing for User Organizations. This process consists of the Information Security team identifying significant risks in their areas of responsibility and implementing appropriate measures to address those risks.

The following steps are involved in performing risk assessments

- Risk identification for each asset in a process and at the Organizational level.
- Risk analysis & evaluation for each asset in a process & at the Organizational level.
- Risk treatment & residual risk.

The Risk Assessment comprises of the criticality of each asset, a list of all threats & vulnerabilities along with impact and probability of occurrence for them (on a rating basis), which are then put into an equation to derive a risk value; this risk value is then compared to the organizational threshold (i.e., accepted risk value) and treated appropriately (i.e., treat, transfer, avoid, accept).

The identified risks will be treated (mitigated) so that risk levels are reduced. The output of a risk assessment will include a completed risk register and risk treatment plan. Any action plans will be tracked to completion.

Regular management meetings are held to discuss the security level, changes, technology trends, occurrence of incidents, and security initiatives.

## Information Security Policies

FELLOWPRO has developed an organization-wide Information Security Policies. Relevant and important Security Policies (IS Policies) are made available to all employees. Changes to the Information Security Policies are reviewed by the IS Team and approved by CEO/CISO prior to implementation.

## Monitoring

Monitoring is a critical aspect of internal control in evaluating whether controls are operating as intended and whether they are modified as appropriate for changes in business conditions. FELLOWPRO management and Information Security personnel monitor the quality of internal control performance as a routine part of their activities.

Performance monitoring reports cover server parameters such as disc space, incoming/outgoing network traffic, packet loss, CPU utilization etc. These system performance reports are reviewed by management on a periodic basis.

In addition, Third Party assessment scan of vulnerabilities is performed on a quarterly basis. Vulnerabilities are evaluated and remediation actions monitored and completed. Results and recommendations for improvement are reported to management.

## Information and Communication

FELLOWPRO has documented procedures covering significant functions and operations for each major work group. Policies and procedures are reviewed and updated based upon suggestions from security personnel and approval by management. Departmental managers monitor adherence to FELLOWPRO policies and procedures as part of their daily activities.

FELLOWPRO management holds departmental status meetings, along with strategic planning meetings, to identify and address service issues, customer problems, and project management concerns. The CTO is the focal point for communication regarding the service activity. Additionally, there are personnel that have been designated to interface with the customer if processing or systems development issues affect customer organizations. Electronic messaging has been incorporated into many of FELLOWPRO's processes to provide timely information to employees regarding daily operating activities and to expedite management's ability to communicate with FELLOWPRO employees.

### Electronic Mail (e-Mail)

Communication to Customer organizations and project teams is through Jira and e-mail. Important corporate events, employee news, and cultural updates are some of the messages communicated using e-mail. E-mail is also a means to draw the attention of employees towards adherence to specific procedural requirements. FELLOWPRO requires two-factor authentications from employees to access their e-mails.

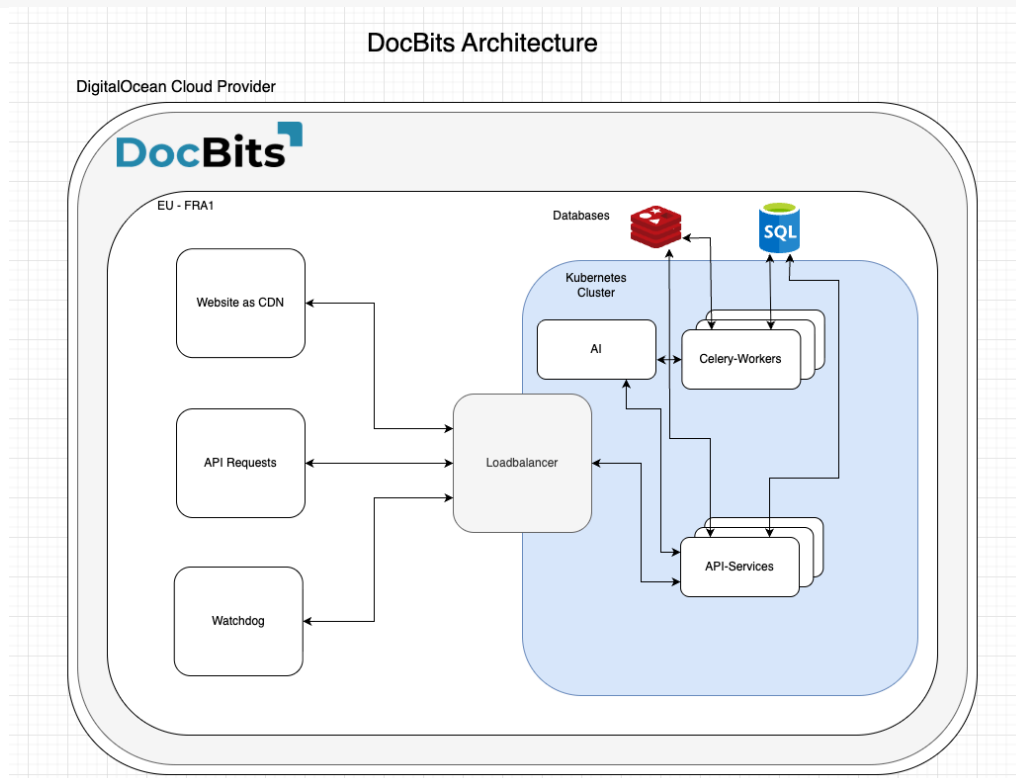
## Components of the System

### Infrastructure

The infrastructure comprises physical and hardware components of the System including facilities, equipment, and networks.

### Network Segmentation Overview

FELLOWPRO's offices are equipped with the latest hardware, software, and networking infrastructure. All the offices are linked through high-speed communication channels, backed up by redundant networks.



## Software

### Firewalls

The production system at Digital Ocean is protected by security group rules (virtual firewall) set up for the virtual private cloud (VPC) provided by Digital Ocean. VPC is used to protect all Production systems hosted at Digital Ocean. Any change to configuration is overseen by the IT Security team. All configurations, backups, and rules have been documented for compliance.

### Network & Endpoint Protection

All systems and devices are protected by the comprehensive endpoint protection system. The endpoints include antivirus, anti-malware, and Trojan protection from any source. This also includes the e-mail scanning of the systems which prevents malicious scripts and viruses from the e-mails. Apart from this, all systems are restricted to the internet with the content filtering system routed through the proxy server.

### Monitoring

FELLOWPRO has devised and implemented adequate monitoring controls to detect unauthorized information processing activities. Critical servers and systems are configured to log user activities, exceptions and information security events. System administrator and system operator activities are logged and reviewed on a periodic basis.

Capacity management controls are put in place to make certain FELLOWPRO's resources are monitored, tuned and projections are made to ensure system performance meets the expected service levels and to minimize the risk of systems failure and capacity related issues. Addition of new information systems and facilities, upgrades, new version and changes are subject to formal system analysis, testing and approval prior to acceptance.

### Patch Management

The information security team ensures that all patches to network device/servers operating systems are tested for stability & availability issues before deploying to the production environment. The patch management activity

is done regularly or as and when any critical event occurs and required updates or patches are installed to ensure efficient working of the servers, desktops and critical network devices. Operating system patches are managed and applied as they become available.

## Vulnerability Scans & Security Audits

As per the Audit calendar, all the network devices and services are audited for vulnerabilities by doing periodic vulnerability scans. These scans are done by the internal IT Infrastructure team.

## Virus Scans and Endpoint Security

FELLOWPRO ensures antivirus is installed with the feature of scanning the device automatically in all the systems and log reports are reviewed by the IT Head. Updates to the virus definition files are managed and downloaded by the software itself on a daily basis from the vendor website at specific intervals.

## People

### Organizational Structure

The organizational structure provides the overall framework for planning, directing, and controlling operations. It has segregated personnel and business functions into functional groups according to their job responsibilities. This approach helps to enable the organization to define responsibilities, lines of reporting, and communication and helps facilitate employees to focus on the specific business issues impacting clients.

The management team meets regularly to review business unit plans and performances. Meetings with the CEO and department heads are held to review operational, security, and business issues, and plans for the future.

FELLOWPRO's Information Security policies define and assign responsibility/accountabilities for information security. Regular management meetings are held to discuss the security level, changes, technology trends, occurrence of incidents, and security initiatives.

The following are the responsibilities of key roles.

- **Executive management** - Responsible for overseeing company-wide activities, establishing, and accomplishing goals, and overseeing objectives.
- **Human resources (HR)** - Responsible for HR policies, practices, and processes with a focus on key HR department delivery areas (e.g., talent acquisitions, employee retention, compensation, employee benefits, performance management, employee relations and training, and development).
- **IT and DevOps** - Responsible for installation, configuration, operation, monitoring, and maintenance of IT and DevOps.
- **IT Security** – Responsible for Information Security including implementing, managing, and monitoring the information security program along with IT Risk Management.
- **Development** - Responsible for the development, testing, deployment, and maintenance of code for internally developed applications

## Processes and Procedures

Formal IT policies and procedures exist that describe physical security, logical access, computer operations, change control, and data communication standards. All teams are expected to adhere to the FELLOWPRO policies and procedures that define how services should be delivered. These are located on the Company's intranet and can be accessed by any FELLOWPRO team member.



## Administrative Level Access

Administrative rights and access to administrative accounts are granted to individuals that require that level of access in order to perform their jobs. All administrative level access, other than to IT team, must be justified to and approved by IT team.

## Confidentiality

Secure procedures are established to ensure safe and secure disposal of media when no longer required. The level of destruction or disposal of media would depend on the information or data stored in the media and the criticality of the information as per the information classification guideline.

## Backup and Recovery of Data

FELLOWPRO has developed formal policies and procedures relating to backup and recovery. Backup is defined in the Backup Policy. Suitable backups are taken and maintained. The backup processes are approved by the business owners and comply with the requirements for business continuity, and legal & regulatory requirements. All backup and restoration logs are maintained for retention periods as defined in the "Backup Policy".

| Control Objective # | Control Area                         | Description                                                                                                                                                                                                                            |
|---------------------|--------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Control Objective 1 | Organization and Management          | Control activities provide reasonable assurance that senior management provide planning and oversight of the organization's activities                                                                                                 |
| Control Objective 2 | Personnel Security Procedures        | Controls provide reasonable assurances that people related risks are mitigated and that all hiring, continued employment, transfers and separation from employment are carried out in accordance with defined policies and procedures. |
| Control Objective 3 | Risk Management                      | Controls provide reasonable assurance that key risks are identified, assessment and mitigation strategies implemented in a timely manner.                                                                                              |
| Control Objective 4 | System Description and Communication | Controls provide reasonable assurance that system components are defined and communicated                                                                                                                                              |
| Control Objective 5 | Network Security                     | Controls provide reasonable assurance that network systems are secured and available as per requirement.                                                                                                                               |
| Control Objective 6 | Physical & Environmental Security    | Controls provide reasonable assurance that physical access to the work area, computer equipment, storage media, and customer provided documentation is restricted to authorized individuals.                                           |

| Control Objective #  | Control Area                          | Description                                                                                                                                                                                                                                                       |
|----------------------|---------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Control Objective 7  | Incident Management                   | Controls provide reasonable assurance that security related incidents are reported, evaluated and resolved in a timely manner                                                                                                                                     |
| Control Objective 8  | Change Management                     | Controls provide reasonable assurance that changes to system components are authorized, designed, developed, configured, documented, tested, approved, and implemented in accordance with policies, commitments and requirements.                                 |
| Control Objective 9  | System Availability                   | Controls provide reasonable assurance that systems are available as per defined SLA.                                                                                                                                                                              |
| Control Objective 10 | Third Party Service Provider Security | Controls provide reasonable assurance that Third Party Service Providers are selected based on Vendor Selection Process, their roles and responsibilities, and performance requirements are formally defined and documented, and they are evaluated periodically. |
| Control Objective 11 | FELLOWPRO Platform                    | Controls provide reasonable assurance that FELLOWPRO Platform Solution are based on documented procedures and are accurately and completely processed.                                                                                                            |

## Complimentary User-Entity Control Considerations

Services provided by FELLOWPRO to user entities and the controls of FELLOWPRO cover only a portion of the overall controls of each user entity. FELLOWPRO controls are designed with the assumption that certain controls are implemented by user entities. In certain situations, applying specific controls at user entities is necessary to achieve relating to the services outlined in this report to be achieved solely by FELLOWPRO. This section highlights those internal control responsibilities that FELLOWPRO believes should be present for each user entity and has considered in developing the controls described in the report. This list does not purport to be and should not be considered a complete listing of the controls relevant to user entities. Other controls may be required at user entities.

1. User Organizations are responsible for ensuring that complete, accurate, and timely information is provided to FELLOWPRO for processing.
2. User Organizations are ultimately responsible for limiting access to only FELLOWPRO employees who are required to perform their job responsibilities and that all users are assigned unique accounts.
3. User Organizations are responsible for monitoring and reviewing their business processes.
4. User Organizations are responsible for ensuring end-customer privacy.
5. User Organizations are responsible for their network security policy and access management for their networks, applications & data.
6. User Organizations are responsible for defining criteria for processing and rejecting items input into their systems.
7. Organizations are responsible for working with FELLOWPRO to jointly establish service levels and revise the same based on changes in business conditions.

## SECTION 4

### DESCRIPTION OF TEST OF CONTROLS AND THEREOF

## Test of Operating Effectiveness and Results of Tests

The tests applied to test the operating effectiveness of controls are listed alongside each of the respective control activities within the Testing Matrices. Accorp Partners considered various factors including, but not limited to, the following:

- the nature of the control and the frequency with which it operates.
- the control risk mitigated by the control.
- the effectiveness of entity-level controls, especially controls that monitor other controls.
- the degree to which the control relies on the effectiveness of other controls; and
- whether the control is manually performed or automated.

The types of tests performed with respect to the operational effectiveness of the control activities detailed in this section are briefly described below:

| Test Approach | Description                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|---------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Inquiry       | Inquired of relevant personnel with the requisite knowledge and experience regarding the performance and application of the related control activity. This included in-person interviews, telephone calls, e-mails, web-based conferences, or a combination of the preceding.                                                                                                                                                                                                          |
| Observation   | Observed the relevant processes or procedures during field work. This included, but was not limited to, witnessing the performance of controls or evidence of control performance with relevant personnel, systems, or locations relevant to the performance of control policies and procedures.                                                                                                                                                                                       |
| Inspection    | Inspected the relevant audit records. This included, but was not limited to, documents, system configurations and settings, or the existence of sampling attributes, such as signatures, approvals, or logged events. In some cases, inspection testing involved tracing events forward to consequent system documentation or processes (e.g., resolution, detailed documentation, alarms, etc.) or vouching backwards for prerequisite events (e.g., approvals, authorizations, etc.) |

### Sampling

Consistent with American Institute of Certified Public Accountants (AICPA) authoritative literature, Accorp Partners utilizes professional judgment to consider the tolerable deviation rate, the expected deviation rate, the audit risk, the characteristics of the population, and other factors, to determine the number of items to be selected in a sample for a particular test. Accorp Partners, in accordance with AICPA authoritative literature, selected samples in such a way that the samples were expected to be representative of the population. This included judgmental selection methods, where applicable, to ensure representative samples were obtained.

## Reliability of Information Provided by the Service Organization

Observation and inspection procedures were performed related to certain system-generated reports, listings, and queries to assess the accuracy and completeness (reliability) of the information used in the performance of our testing of the controls.

## Independent Service Auditor's Description of Tests of Controls and Results

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                  | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                                                                                        | Test Results        |
|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
| 1         | <b>Organisation and Management</b><br>Control Objective: Control activities provide reasonable assurance that senior management provides planning and oversight of the organization's activities                                        |                                                                                                                                                                                                                                                                                                                                                       |                     |
|           | Terms of employment and ethical and behavioral values and expectations are communicated via employment contracts and the code of conduct.                                                                                               | Inspected the code of conduct and an example employment contract to determine that terms of employment and FELLOWPRO's ethical and behavioral values and expectations were communicated via employment contracts and the code of conduct.                                                                                                             | No Exceptions Noted |
|           | Mandatory security awareness training includes security requirements and expectations of employees in achieving internal control responsibilities to meet business and regulatory objectives.                                           | Inspected the security and privacy awareness training material to determine that mandatory security awareness training included security requirements and expectations of FELLOWPRO employees in achieving internal control responsibilities to meet business and regulatory objectives.                                                              | No Exceptions Noted |
|           | Employees receive code of conduct training on at least an annual basis to ensure that employees acknowledge the policies that comprise the code of conduct and the importance of the code of conduct to FELLOWPRO's business practices. | Inspected the code of conduct training material and results for a sample of current employees to determine that training was completed during the period for each employee sampled to ensure that employees acknowledged the policies that comprised the code of conduct and the importance of the code of conduct to FELLOWPRO's business practices. | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                      | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                             | Test Results           |
|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------|
|           | Employees receive security and privacy awareness education and refresher training at least on an annual basis.                                                                              | Inspected the security and privacy awareness education and refresher training results for a sample of current employees to determine that security and privacy awareness education and training was completed during the period for each employee sampled. | No Exceptions<br>Noted |
|           | All new employees have to read and sign the Confidentiality Agreement/NDA upon joining.                                                                                                     | Selected a sample of new joiners and inspected personnel files to determine that Confidentiality agreements / NDAs are signed.                                                                                                                             | No Exceptions<br>Noted |
|           | Agreements are established with third parties or subcontractors that include clearly defined terms, conditions, and responsibilities for third parties and subcontractors.                  | Selected a sample and inspected the vendor agreements to determine that the agreements define the terms, conditions, and responsibilities of these vendors and their subcontractors.                                                                       | No Exceptions<br>Noted |
|           | Customer can provide their issues, complaints, or feedback through email to Business Heads. Employees can raise their complaints and grievances to HR.                                      | Inspected customer resolution clauses in a sample of customer Statement of Work (SOW) and Client Contracts and determined that customers have a mechanism to communicate with FELLOWPRO.                                                                   | No Exceptions<br>Noted |
|           | Management Review Meetings are held every year to discuss the security level, Internal Audit results, Risks, changes, technology trends, occurrence of incidents, and security initiatives. | Selected a sample of Management Review Meetings held and inspected the minutes to determine that these are held on annually.                                                                                                                               | No Exceptions<br>Noted |
|           | The Management team meets monthly and discusses the business as well as operational issues.                                                                                                 | Selected a sample of management meetings held and inspected the minutes to determine that management meetings are held on a periodic basis.                                                                                                                | No Exceptions<br>Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                                                                           | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                    | Test Results        |
|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | Conflicting duties and areas of responsibility are segregated to reduce opportunities for unauthorized or unintentional modification or misuse of the organization's assets.                                                                                                                     | Inspected the organization chart to determine that conflicting duties and areas of responsibility were segregated to reduce opportunities for unauthorized or unintentional modification or misuse of the organization's assets.                  | No Exceptions Noted |
|           | Organization has Information security policies and procedures that describe information security processes, practices.                                                                                                                                                                           | Inspected Information Security policies and procedures to determine that these are documented, approved and reviewed by the management at least annually.                                                                                         | No Exceptions Noted |
| <b>2</b>  | <b>Personnel Security Procedures</b><br>Control Objective: Controls provide reasonable assurance that people related risks are mitigated and that all hiring, continued employment, transfers and separation from employment are carried out in accordance with defined policies and procedures. |                                                                                                                                                                                                                                                   |                     |
|           | <b>New Hire Procedures</b>                                                                                                                                                                                                                                                                       |                                                                                                                                                                                                                                                   |                     |
|           | Organization has established HR policies and procedures including recruitment, training, and exit                                                                                                                                                                                                | Inspected the HR Policies and procedures to determine that Policies and procedures including recruitment, training, and exit are established.                                                                                                     | No Exceptions Noted |
|           | Job descriptions are in place which define roles and responsibilities, skills, knowledge levels and required competencies.                                                                                                                                                                       | Inspected the job description for a sample of current employees to determine that documented job descriptions were in place for each employee sampled and defined roles and responsibilities, skills, knowledge levels and required competencies. | No Exceptions Noted |
|           | New employees sign the offer letter as their agreement and acceptance of broad terms of employment including a brief description of the position and other terms.                                                                                                                                | Selected a sample of new joiners and inspected the appointment letter to determine that new joiners accept the terms of employment.                                                                                                               | No Exceptions Noted |



| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                                                | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                                                                                         | Test Results        |
|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | Employees receive security and privacy awareness education and training upon hire.                                                                                                                                                                                    | Inspected the security and privacy awareness training results for a sample of employees hired during the period to determine that security and privacy awareness education and training was completed upon hire for each employee sampled.                                                                                                             | No Exceptions Noted |
| <b>3</b>  | <b>Risk Management</b><br>Control Objective: Controls provide reasonable assurance that key risks are identified, assessment and mitigation strategies implemented in a timely manner                                                                                 |                                                                                                                                                                                                                                                                                                                                                        |                     |
|           | FELLOWPRO has defined and applies an information security risk assessment process.<br>FELLOWPRO has a risk management framework established to identify, report, and manage risks across key risk categories, including operational, strategic, legal, and financial. | Inspected a sample of internal audit reports & the corrective action taken to determine that an effective internal audit process is in place annually.                                                                                                                                                                                                 | No Exceptions Noted |
|           | Risk assessments are performed on in-scope FELLOWPRO assets for the information security management system and take into account threats to and vulnerabilities of the asset. The results of the risk assessments are reviewed by management at least annually.       | Inspected the FELLOWPRO asset register, the most recent risk register, and the Management Review meeting invite and agenda determine that risk assessments were performed on in-scope assets during the period and took into account threats to and vulnerabilities of the asset, and the results of the risk assessments were reviewed by management. | No Exceptions Noted |
|           | FELLOWPRO evaluates the information security performance and the effectiveness of the ISMS on at least an annual basis.                                                                                                                                               | Inspected the most recent internal audit report and ISMS management review to determine that FELLOWPRO evaluated the information security performance and the effectiveness of the ISMS during the period.                                                                                                                                             | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                         | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                      | Test Results        |
|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | FELLOWPRO has an internal business assurance function which provides independent and objective assurance and advice on FELLOWPRO's organisational governance, risk management, and internal control processes. | Inspected the security assurance, performance, and compliance framework to determine that an internal business assurance function provided independent and objective assurance and advice on FELLOWPRO's organisational governance, risk management and internal control processes. | No Exceptions Noted |
|           | Risk Assessment Scales (Risk Rating scales) are defined to evaluate and assess the significance of Risk. This is part of the Risk Management Framework.                                                        | Inspected Risk Assessment and Risk Treatment procedure to determine that Risk Assessment Scales (Risk Rating scales) are defined to evaluate and assess the significance of Risk.                                                                                                   | No Exceptions Noted |
|           | Risk Assessment and Risk Treatment Procedure related to risk management are developed, implemented, and communicated to personnel.                                                                             | Inspected Risk Assessment and Risk Treatment Procedures to determine that the FELLOWPRO has a defined and documented risk assessment process.                                                                                                                                       | No Exceptions Noted |
| <b>4</b>  | <b>System Description and Communication</b><br>Control Objective: Controls provide reasonable assurance that system components are defined and communicated.                                                   |                                                                                                                                                                                                                                                                                     |                     |
|           | System boundaries in terms of logical and physical boundaries are documented and network architecture diagrams are in place. System Boundaries are shared with the customers when it is required.              | Inspected the network architecture diagram to determine that system boundaries in terms of logical and physical boundaries are documented.                                                                                                                                          | No Exceptions Noted |
|           | Customer responsibilities and appropriate system descriptions are provided in client contracts.                                                                                                                | Inspected sampled client contracts to determine that terms related to brief requirements of the system and customer responsibilities are documented.                                                                                                                                | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                                                                            | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                                                               | Test Results        |
|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | A ticketing system is in place which allows internal and external system users to report security failures, incidents, and concerns. Incidents and security incidents are responded to and managed to resolution by the incident response manager and the security operations team, respectively. | Inspected the incident ticket for a sample of incidents during the period to determine that a ticketing system was in place which allowed internal and external system users to report security failures, incidents and concerns, and incidents, and security incidents were responded to and managed through to resolution. | No Exceptions Noted |
|           | FELLOWPRO requires employees as part of signing their employment contract, and contractors, to sign agreements that include non-disclosure provisions and asset protection responsibilities, upon hire.                                                                                           | Inspected the signed NDA for a sample of employees and contractors hired during the period to determine that FELLOWPRO required employees to sign agreements that included non-disclosure provisions and asset protection responsibilities, upon hire, for each employee sampled.                                            | No Exceptions Noted |
|           | NDAs are established with third parties during the procurement process where sensitive information is included within the scope of the services to be provided to FELLOWPRO.                                                                                                                      | Inspected the NDA established with a sample of vendors onboarded during the period to determine that NDAs were established during the procurement process for each vendor sampled where sensitive information was included within the scope of the services to be provided to FELLOWPRO.                                     | No Exceptions Noted |
|           | Incidents impacting external users are communicated to them through emails along with root cause analysis, if required.                                                                                                                                                                           | Enquired with the management that Incidents impacting external users are communicated to them through emails along with root cause analysis, if required.                                                                                                                                                                    | No Exceptions Noted |
|           | All information assets are identified in an asset inventory.                                                                                                                                                                                                                                      | Inspected the Asset Inventory to determine that all information assets are identified in an asset inventory.                                                                                                                                                                                                                 | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                                   | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                                                     | Test Results        |
|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | The IT department maintains an up-to-date listing of all software and the security patches related to OS and application and patches are monitored.                                                                                                      | Inspected sampled laptops to determine that latest patches are updated.                                                                                                                                                                                                                                            | No Exceptions Noted |
|           | FELLOWPRO has an internal business assurance function which provides independent and objective assurance and advice on FELLOWPRO's organisational governance, risk management, and internal control processes.                                           | Inspected the security assurance, performance, and compliance framework to determine that an internal business assurance function provided independent and objective assurance and advice on FELLOWPRO's organisational governance, risk management and internal control processes.                                | No Exceptions Noted |
|           | Conflicting duties and areas of responsibility are segregated to reduce opportunities for unauthorized or unintentional modification or misuse of the organization's assets.                                                                             | Inspected the organization chart to determine that conflicting duties and areas of responsibility were segregated to reduce opportunities for unauthorized or unintentional modification or misuse of the organization's assets.                                                                                   | No Exceptions Noted |
|           | FELLOWPRO has defined and documented access control policy that outline processes for identifying and authenticating authorized users, restricting user access to authorized system components, and preventing and detecting unauthorized system access. | Inspected the access control policy to determine that FELLOWPRO defined and documented standards for access control that outlined processes for identifying and authenticating authorized users, restricting user access to authorized system components, and preventing and detecting unauthorized system access. | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                          | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                      | Test Results        |
|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | FELLOWPRO has an internal business assurance function which provides independent and objective assurance and advice on FELLOWPRO's organisational governance, risk management, and internal control processes.                  | Inspected the security assurance, performance, and compliance framework to determine that an internal business assurance function provided independent and objective assurance and advice on FELLOWPRO's organisational governance, risk management and internal control processes. | No Exceptions Noted |
|           | FELLOWPRO has documented procedures for logical access controls.                                                                                                                                                                | Inspected the access control policy and procedure and determined that these are documented.                                                                                                                                                                                         | No Exceptions Noted |
|           | Access is granted on least privileges basis as default and any additional access needs to be approved.                                                                                                                          | Inspected access control procedure document and determined that access is granted on a least privileges basis as default and any additional access needs to be approved.                                                                                                            | No Exceptions Noted |
|           | The Engineering team has formally documented standard build procedures for installation and maintenance of the database and code repository that includes the requirement for access control systems to enforce logical access. | Inspected the evidence to determine that the Engineering team has formally documented standard build procedures for installation and maintenance of database and code repository that includes the requirement for access control systems to enforce logical access                 | No Exceptions Noted |
|           | FELLOWPRO has established hardening standards in production infrastructure that include requirements for the implementation of security groups, access control, configuration settings, and standardized policies.              | Inspected the hardening standards to determine that hardening standards have been established.                                                                                                                                                                                      | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                            | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                  | Test Results        |
|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | Production hosts and Security Groups (which are the equivalent of Firewalls) are hardened according to Industry best practices. Only the required ports are opened for inbound access at the load balancer level. | Inspected Digital Ocean settings to determine that VPC has been set up and all production servers are within the private subnet. Inspected the IAM settings and security groups to determine that only the production group has access to production resources. | No Exceptions Noted |
|           | The in-scope systems and applications are configured to authenticate users with a unique user account and enforce minimum password requirements or SSH public key authentication.                                 | Inspected the evidence to determine that the in-scope systems and applications are configured to authenticate users with a unique user account and enforce minimum password requirements or SSH public key authentication.                                      | No Exceptions Noted |
|           | Cloud infrastructure is configured to use the Digital Ocean's identity and access management system (IAM). Relevant groups have been added to IAM.                                                                | Inspected the IAM settings and security groups to determine that several groups have been formed for different teams and only the production group has access to production resources.                                                                          | No Exception Noted  |
|           | For Digital Ocean console access, Multi-Factor Authentication is implemented.                                                                                                                                     | Inspected the user settings in the Digital Ocean console for the production group members to determine that multifactor authentication has been enabled.                                                                                                        | No Exceptions Noted |
|           | Privileged access is allocated to users on a need-to-use basis in line with their job responsibilities and is controlled as per the access control policy.                                                        | Inspected the access control policy, listing of Digital Ocean administrators to determine that privileged access was allocated to users on a need-to-use basis in line with their job responsibilities and was controlled as per the access control policy.     | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                  | Test Procedures Applied by the Service Auditor                                                                                                                                                                                     | Test Results        |
|-----------|-----------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | Predefined security groups are in place for in-scope systems using role-based access privileges.                                        | Inspected the listing of Digital Ocean user groups to determine that predefined security groups were in place for in-scope systems using role-based access privileges.                                                             | No Exceptions Noted |
|           | Data storage mechanisms are configured to encrypt data at rest in accordance with the cryptography standard.                            | Inspected the data at rest encryption configurations to determine that data storage mechanisms were configured to encrypt data at rest in accordance with the cryptography standard.                                               | No Exceptions Noted |
|           | Permissions to individual accounts are restricted based on roles and job requirements.                                                  | Inspected the user access request for a sample of requests to the in-scope data systems and services during the period to determine that permissions to individual accounts was restricted based on roles and job requirements.    | No Exceptions Noted |
|           | Access to in-scope systems requires users to authenticate via an individual user account using multi-factor or two-step authentication. | Inspected the Digital Ocean management and authentication configurations to determine that access to in scope systems required users to authenticate via an individual user account using multi-factor or two-step authentication. | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                                                                                                                                        | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                                                                                                                                                            | Test Results        |
|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | On the day of joining, HR will send a mail to the IT Help desk providing the details of the new joiners. The IT then provides necessary access as per the request. Employee user accounts are removed from various applications and network systems as of the last date of employment manually based on access revocation requests sent by the HR department. | Inspected the Access Control policy to determine that granting, modifying, or deactivating access is only done against written authorization.<br>Inspected access request forms/emails for a sample of employees to determine that written authorization is in place. Inspected access revocation request /exit checklist for a sample of employees to determine that written authorization for deactivation is in place. | No Exceptions Noted |
|           | When an employee leaves the organization, the employee's manager initiates the 'Exit Process'. HR informs respective teams / IT teams within 24 hours to deactivate/delete the user ID from the email system and all applications. An exit checklist is used to ensure compliance with termination procedures.                                                | Selected a sample of exited users and inspected Email from HR to IT and Exit Checklist to determine that the exit process and related account deactivation is as per defined procedures.<br>Inspected Digital Ocean IAM to determine that the exited user has disabled status.                                                                                                                                            | No Exceptions Noted |
|           | Access to data, systems and services in-scope systems is reviewed on a quarterly basis to confirm access is still appropriate.                                                                                                                                                                                                                                | Inspected the user access review for a sample of quarters to determine that access to data, systems and services in-scope systems was reviewed for each quarter sampled to confirm access was still appropriate.                                                                                                                                                                                                          | No Exceptions Noted |
|           | A role based security process has been defined with in Digital Ocean infrastructure based on job requirements.                                                                                                                                                                                                                                                | Inspected the Digital Ocean console screens to determine that security groups based on departments and roles have been defined.                                                                                                                                                                                                                                                                                           | No Exceptions Noted |



| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                                                                                          | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                                                                           | Test Results        |
|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | Permissions to individual accounts are restricted based on roles and job requirements.                                                                                                                                                                                                                          | Inspected the user access request for a sample of requests to the in-scope data systems and services during the period to determine that permissions to individual accounts was restricted based on roles and job requirements.                                                                                                          | No Exceptions Noted |
|           | Company does not allow reactivation of ID belonging to an exited employee.                                                                                                                                                                                                                                      | Enquired with IT Head that reactivation of IDs it is prohibited.                                                                                                                                                                                                                                                                         | No Exceptions Noted |
| <b>5</b>  | <b>Network Security</b><br>Control Objective: Controls provide reasonable assurance that network systems are secured and available as per requirement.                                                                                                                                                          |                                                                                                                                                                                                                                                                                                                                          |                     |
|           | The production system at Digital Ocean is protected by security group rules (virtual firewall) set up for the virtual private cloud (VPC) provided by Digital Ocean. VPC is used to protect all Production systems hosted at Digital Ocean.                                                                     | Inspected Digital Ocean settings to determine that VPC has been set up and direct access to production instances is only through 2048-bit SSH keys.                                                                                                                                                                                      | No Exceptions Noted |
|           | Access to modify security group rules is restricted by IT Head to administrators.                                                                                                                                                                                                                               | Inspected the user list on IAM to determine that access to modify security group rules is restricted to only administrators.                                                                                                                                                                                                             | No Exceptions Noted |
|           | Connections to the Digital Ocean-hosted servers are through authenticated SSH sessions or authenticated secure browser sessions using HTTPS.                                                                                                                                                                    | Inspected Digital Ocean settings to determine that direct access to production instances is only through SSH keys.                                                                                                                                                                                                                       | No Exceptions Noted |
|           | The cryptography standard defines the security controls and operational practices applicable to customer data at rest, end user devices, backups, and web communication sessions. The standard also defines requirements for the annual generation, use, protection, audit, and rotation of cryptographic keys. | Inspected the cryptography and encryption policy to determine that it defined the security controls and operational practices applicable to customer data at rest, end user devices, backups, and web communication sessions and the requirements for the annual generation, use, protection, audit, and rotation of cryptographic keys. | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                    | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                                               | Test Results        |
|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | Information involved in application services which passes over public networks is encrypted as per the established standards for data controls and for cryptography.                                                                      | Inspected the cryptography and encryption policy, the TLS encryption certificate, and SSL labs report to determine that information involved in application services which passes over public networks was encrypted as per the established standards for data controls and for cryptography.                | No Exceptions Noted |
|           | Transport encryption requirements are defined within the cryptography standard and comply with legal and regulatory requirements.                                                                                                         | Inspected the cryptography and encryption policy to determine that transport encryption requirements were defined within the cryptography standard and complied with legal and regulatory requirements.                                                                                                      | No Exceptions Noted |
|           | Data storage mechanisms are configured to encrypt data at rest in accordance with the cryptography standard.                                                                                                                              | Inspected the data at rest encryption configurations to determine that data storage mechanisms were configured to encrypt data at rest in accordance with the cryptography standard.                                                                                                                         | No Exceptions Noted |
|           | Antivirus protection is enabled on end-user devices and virus definitions are updated automatically. Network traffic is inspected for malware, application, and server vulnerabilities, insider threats and unwanted application traffic. | Inspected the antivirus configurations to determine that antivirus protection was enabled on end-user devices and virus definitions were updated automatically and that network traffic was inspected for malware, application and server vulnerabilities, insider threats and unwanted application traffic. | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                                          | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                   | Test Results        |
|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | Security monitoring systems are in place to monitor and analyse the in-scope systems for possible or actual security breaches.                                                                                                                                  | Inspected the logging and monitoring application configurations and example alerts generated during the period to determine that security monitoring systems were in place to monitor and analyse the in-scope systems for possible or actual security breaches. | No Exceptions Noted |
|           | Systems in the production environment are hardened, based on CIS benchmarks.                                                                                                                                                                                    | Inspected the CIS benchmark and hardening guidelines to determine that systems in the production environment were hardened, based on CIS benchmarks.                                                                                                             | No Exceptions Noted |
|           | Management has defined configuration standards and hardening standards.                                                                                                                                                                                         | Inspected the system hardening checklist to determine that Management has defined configuration standards and hardening standards.                                                                                                                               | No Exceptions Noted |
|           | FELLOWPRO monitors infrastructure and software for non-compliance with the standards, which could threaten the achievement of the organization's objectives.                                                                                                    | Inspected the Grafana dashboard to determine entity monitors infrastructure and software for noncompliance with the standards.                                                                                                                                   | No Exceptions Noted |
|           | Vulnerability assessment & penetration tests are performed at least annually by a third party.                                                                                                                                                                  | Inspected the latest vulnerability assessment /penetration test report performed by a third party and determined that these are carried out at least and that vulnerabilities were closed.                                                                       | No Exceptions Noted |
| <b>6</b>  | <b>Physical &amp; Environmental Security</b><br>Control Objective: Controls provide reasonable assurance that physical access to the work area, computer equipment, storage media, and customer-provided documentation is restricted to authorized individuals. |                                                                                                                                                                                                                                                                  |                     |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                   | Test Procedures Applied by the Service Auditor                                                                                                               | Test Results        |
|-----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | Physical access is set up by the HR Dept for new joiners after all HR formalities are completed. ID cards by default do not have access to any of the sensitive areas.                                                                   | Selected a sample of new employees and inspected that the access rights were granted in the physical access system only to authorized new joiners.           | No Exceptions Noted |
|           | A periodic review of physical access to sensitive areas against the active employee list is carried out by IT.                                                                                                                           | Inspected a sample of Internal Audit Report and IT Dept Rating criteria to determine that access review reports for sensitive areas were reviewed regularly. | No Exceptions Noted |
|           | Upon the last day of employment, physical access is deactivated by the HR Team.                                                                                                                                                          | Inspected biometric system to determine that the employee ID numbers for the sample of exited employees were deleted from the electronic-based system.       | No Exceptions Noted |
|           | All visitors have to enter their details in the visitor register.                                                                                                                                                                        | Inspected the visitor register for a sample of dates to determine that the visitor register was maintained                                                   | No Exceptions Noted |
|           | Environmental controls (fire extinguishers and smoke detectors) have been installed to protect the perimeter area. CCTV is installed at key points for surveillance.<br><br>Devices are checked periodically and checklists are prepared | Observed fire extinguishers across all office premises that are in working condition.<br><br>Observed other environmental controls.                          | No Exceptions Noted |
|           | Uninterruptible power supply (UPS) devices are in place to secure critical IT equipment against power failures and fluctuations.                                                                                                         | Observed the UPS installed at the premises to determine that they are in good working condition.                                                             | No Exceptions Noted |
|           | Organization has multiple ISPs in place to provide redundancy in case of link failure                                                                                                                                                    | Inspected the network diagram to determine that the company has multiple ISPs in place.                                                                      | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                                                                                                                                                   | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                                                                                                                                                                            | Test Results        |
|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
| 7         | <b>Incident Management</b><br>Control Objective: Controls provide reasonable assurance that security related incidents are reported, evaluated and resolved in a timely manner                                                                                                                                                                                           |                                                                                                                                                                                                                                                                                                                                                                                                                                           |                     |
|           | Documented incident response procedures are in place to guide personnel that handle incidents and include the process for informing the entity about actual and potential events that impact system security and for submitting complaints as well as roles and responsibilities for teams involved. Procedures are communicated to employees and customers as required. | Inspected the security incident response plan and procedures to determine that documented procedures were in place to guide personnel in the handling of incidents and included the process for informing the entity about actual and potential events that impacted system security and for submitting complaints as well as roles and responsibilities for teams involved, and procedures were communicated to employees and customers. | No Exceptions Noted |
|           | The IT team receives requests for support through phones, emails, and the Jira which may include requests to reset user passwords, etc.                                                                                                                                                                                                                                  | Inspected a sample of IT support ticket emails reported by users to determine that support tickets are logged as Jira tickets.                                                                                                                                                                                                                                                                                                            | No Exceptions Noted |
|           | Reported incidents are logged in Excel/Incident form and include the following details: <ul style="list-style-type: none"> <li>• Incident Type</li> <li>• Data and Time of incident</li> <li>• Details</li> <li>• Action Taken</li> <li>• Root Cause (For select high-risk incidents)</li> </ul>                                                                         | Inspected a sample of the incident report to determine that incidents covered the following: <ul style="list-style-type: none"> <li>• Incident Type</li> <li>• Data and Time of incident</li> <li>• Details</li> <li>• Action Taken</li> <li>• Root Cause (For select high-risk incidents)</li> </ul>                                                                                                                                     | No Exceptions Noted |
|           | All security incidents are also reviewed and monitored by the Information Security Group. Corrective and preventive actions are completed for incidents.                                                                                                                                                                                                                 | Inspected minutes MRM meeting minutes to determine that discussion on incidents takes place.                                                                                                                                                                                                                                                                                                                                              | No Exceptions Noted |
|           | All incidents are evaluated and necessary action taken to close the threat/vulnerability.                                                                                                                                                                                                                                                                                | Inspected Incident Management Procedure and determined that necessary action is taken to close the threat/vulnerability.                                                                                                                                                                                                                                                                                                                  | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                      | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                  | Test Results        |
|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | Management reviews all incidents that occurred during the year as part of Management Review Meeting.                                                                                                        | Inspected MRM meeting minutes to determine that annually management reviews all incidents that occurred during the year is conducted.                                                                                                                                           | No Exceptions Noted |
| <b>8</b>  | <b>Change Management</b><br>Control Objective: Controls provide reasonable assurance that software development and maintenance activities are authorized, tested, approved, implemented and documented.     |                                                                                                                                                                                                                                                                                 |                     |
|           | Application development and testing on FELLOWPRO platform are done in separate environments from production.                                                                                                | Inspected the evidence to determine that the platform application development and testing are done in separate environments from production.                                                                                                                                    | No Exceptions Noted |
|           | FELLOWPRO uses a version control system to manage source code, documentation, release labeling, and other change management tasks. Access to the system must be approved by a system admin.                 | Inspected the screenshot from the version control/code repository to determine that FELLOWPRO uses a version control system to manage source code, documentation, release labeling, and other change management tasks. Access to the system must be approved by a system admin. | No Exceptions Noted |
|           | Application code changes, code reviews, and tests are performed by someone other than the person who made the code change.                                                                                  | Inspected the company records to determine that FELLOWPRO's application code changes, code reviews, and tests are performed by someone other than the person who made the code change.                                                                                          | No Exceptions Noted |
|           | Authorized FELLOWPRO personnel can push or make changes to production code.                                                                                                                                 | Inspected the company records to determine that authorized FELLOWPRO personnel can push or make changes to production code.                                                                                                                                                     | No Exceptions Noted |
|           | All change requests are submitted with Risk Assessment, implementation, and rollback plans. The code repository & deploy tool has a turnover process that includes back out steps commit is to be reverted. | Inspected a sample of change requests to determine that they had Risk Assessment, implementation, and rollback plans included.                                                                                                                                                  | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                                                                                                                     | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                                                                                                                       | Test Results        |
|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|           | Changes are communicated to the appropriate client and user community if the change has any potential impact on the user base.                                                                                                                                                                                                             | Enquired with IT Head that changes are communicated to clients and end users if it has an impact on those users.                                                                                                                                                                                                                                                                     | No Exceptions Noted |
|           | Change management policies and procedures are in place to guide personnel in the request, documentation, testing, and approval of changes. The policies and procedures also outline the requirement for segregation of duties such that authorization, development, testing and implementation are segmented functions within the process. | Inspected the change management policies and procedures to determine that these were in place to guide personnel in the request, documentation, testing, and approval of changes.<br>The policies and procedures also outline the requirement for segregation of duties such that authorization, development, testing and implementation are segmented functions within the process. | No Exceptions Noted |
| 9         | <b>System Availability</b><br>Control Objective: Controls provide reasonable assurance that systems are available as per defined SLA.                                                                                                                                                                                                      |                                                                                                                                                                                                                                                                                                                                                                                      |                     |
|           | A monitoring system is utilized to monitor system performance and operations, including unusual activities, system uptime, system processing, CPU usage, and memory storage.                                                                                                                                                               | Inspected the Grafana dashboard to determine that a monitoring system is utilized to monitor system performance and operations, including unusual activities, system uptime, system processing, CPU usage, and memory storage.                                                                                                                                                       | No Exceptions Noted |
|           | Load balancing is enforced to distribute network traffic across multiple infrastructure resources within the cloud IT environment.                                                                                                                                                                                                         | Inspected the evidence to determine that load balancing is enforced to distribute network traffic across multiple infrastructure resources within the cloud IT environment.                                                                                                                                                                                                          | No Exceptions Noted |
|           | Auto-scaling is enforced within the cloud IT environment to automatically scale infrastructure resources to support network workload and facilitate continued operations.                                                                                                                                                                  | Inspected the company records to determine that auto-scaling is enforced within the cloud IT environment to automatically scale infrastructure resources to support network workload and facilitate continued operations.                                                                                                                                                            | No Exceptions Noted |

| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                                                  | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                                                   | Test Results           |
|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------|
|           | Processing capacity for cloud infrastructure is monitored on an ongoing basis.                                                                                                                                                                                          | Inspected dashboard of Digital Ocean Monitor to determine that alerts & thresholds have been setup for abnormal conditions such as low CPU utilization, network outage, free storage, etc.                                                                                                                       | No Exceptions<br>Noted |
|           | Incremental and full backup procedures are performed on production databases, on a daily basis to store duplicate copies of data for system availability and data restoration in the event of a business disruption or security incident.                               | Inspected the evidence to to determine that incremental and full backup procedures are performed on production databases, on a daily basis to store duplicate copies of data for system availability and data restoration in the event of a business disruption or security incident.                            | No Exceptions<br>Noted |
|           | The FELLOWPRO platform is implemented in a high-availability configuration which uses multiple, redundant availability zones and is based on the good practice guidelines set by the cloud provider.                                                                    | Inspected the Digital Ocean server and database configurations to determine that the Digital Ocean platform was implemented in a high- availability configuration which used multiple, redundant availability zones based on the good practice guidelines set by Digital Ocean.                                  | No Exceptions<br>Noted |
|           | Management performs annual testing of the Business Continuity and Disaster Recovery (BCDR) plan to evaluate the effectiveness of its defined procedures.<br>Issues identified during testing procedures are investigated and remediated to remediate identified issues. | Inspected the evidence to determine that management performs annual testing of the Business Continuity and Disaster Recovery (BCDR) plan to evaluate the effectiveness of its defined procedures.<br>Issues identified during testing procedures are investigated and remediated to remediate identified issues. | No Exceptions<br>Noted |
|           | Business continuity plans, including restoration of backups, are tested at least annually.                                                                                                                                                                              | Inspected backup restoration test report to determine that restoration tests are conducted at least annually.                                                                                                                                                                                                    | No Exceptions<br>Noted |



| Control # | Control Activity Specified by the Service Organization                                                                                                                                                                                                                                                                              | Test Procedures Applied by the Service Auditor                                                                                                                                                                                                                                                         | Test Results        |
|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
| 10        | <b>Third Party Service Provider Security</b><br>Control Objective: Controls provide reasonable assurance that Third Party Service Providers are selected based on Vendor Selection Process, their roles and responsibilities, and performance requirement are formally defined and documented, and they are evaluated periodically. |                                                                                                                                                                                                                                                                                                        |                     |
|           | FELLOWPRO management reviews the annual SOC report for its sub-processors to confirm that outsourced controls are appropriately designed and operating effectively.                                                                                                                                                                 | Inspected the company records to determine that FELLOWPRO's management reviews the annual SOC report for its sub-processors to confirm that outsourced controls are appropriately designed and operating effectively.                                                                                  | No Exceptions Noted |
|           | A vendor management process is in place and requires signed contracts for vendors and includes (1) scope of services and product specifications, (2) roles and responsibilities, (3) compliance requirements, and (4) service levels where applicable.                                                                              | Inspected the company records to determine that a vendor management process is in place and requires signed contracts for vendors and includes (1) scope of services and product specifications, (2) roles and responsibilities, (3) compliance requirements, and (4) service levels where applicable. | No Exceptions Noted |
|           | A formal contract is executed between the Company and Third-Party Service Providers before the work is initiated. The agreement includes terms of confidentiality and responsibilities of both parties.                                                                                                                             | Inspected a sample of vendor contracts to determine that vendor's contracts are in place which includes terms of confidentiality and responsibilities of both parties.                                                                                                                                 | No Exceptions Noted |
|           | All customer & vendor contracts have signed NDA.                                                                                                                                                                                                                                                                                    | Inspected signed NDA and vendor contracts for sample vendors to determine that they NDA is signed.                                                                                                                                                                                                     | No Exceptions Noted |

| 11 | FELLOWPRO Platform/Solution                                                                                                                                                                                                                                                                                                      |                                                                                                                                                                                                                                                                                                                                 |                     |
|----|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|    | Control Objective: Controls provide reasonable assurance that FELLOWPRO Platform/Solution are based on documented procedures and are accurately and completely processed.                                                                                                                                                        |                                                                                                                                                                                                                                                                                                                                 |                     |
|    | Client Setup and Migration                                                                                                                                                                                                                                                                                                       |                                                                                                                                                                                                                                                                                                                                 |                     |
|    | <p>The organization follows a structured process for client acquisition, onboarding, and project execution. Clients are typically acquired through various channels, including Infor events, LinkedIn campaigns, face-toface meetings, and Infor user groups. Once a client is engaged, the onboarding process is initiated.</p> | <p>Inspected campaigns scheduled over platforms like LinkedIn for client acquisition.</p> <p>Reviewed sample email reach-outs to the prospects before the project initiation and onboarding</p>                                                                                                                                 | No Exceptions Noted |
|    | <p>The organization ensures that every project engagement is governed by a formal Statement of Work (SOW), detailing the project's scope, deliverables, timelines, and responsibilities.</p>                                                                                                                                     | <p>Inspected the project engagement process documented in Statements of Work (SOW). Sample client SOW outlining the project scope, deliverables, timelines, and responsibilities was reviewed.</p> <p>Validated the section for out-of-scope services from the SOW for the purpose of unambiguity during client engagement.</p> | No Exceptions Noted |

|                              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |                     |
|------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|                              | <p>As a Part of Client Onboarding Following Documents are exchanged between FELLOWPRO and the Client entity :</p> <p><b>Non-Disclosure Agreement (NDA) :</b> A formal Confidentiality and Non-Disclosure Agreement (NDA) is signed with each client before the commencement of any engagement.</p> <p><b>Order Form :</b> This document serves as a formal record of the client's purchase, Pricing is clearly defined based on the user count and the specific software modules the client opts for, with no variability once the terms are agreed upon.</p> <p><b>Master Service Agreement (MSA) :</b> The organization implements a structured Master Services Agreement (MSA) as part of the client onboarding process, ensuring clear documentation of services, offerings, third-party vendor involvement, and data management.</p> <p>Contract termination clauses and Legal Terms of Services are agreed upon between FELLOWPRO and the Client entity.</p> | <p>Inspected the client onboarding process and the exchange of critical legal and operational documents between FELLOWPRO and the client entity.</p> <p>Reviewed evidence includes the Non-Disclosure Agreement (NDA), which is signed before any engagement to ensure confidentiality. Order Forms were examined, which formally document the client's purchase, detailing fixed pricing based on user count and software modules chosen.</p> <p>Additionally, the Master Service Agreement (MSA) was reviewed, outlining the scope of services, third- party vendor involvement, and data management procedures.</p> | No Exceptions Noted |
| Client Setup on DigitalOcean |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |                     |
|                              | <p>The organization manages client access to the DocBits application through a centralized URL, <a href="https://www.docbits.com">https://www.docbits.com</a> ,which is hosted using the Microservices, FastAPI and Vue.js. Each client entity is provided with designated Admin and User accounts, ensuring controlled access to the application.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | <p>Inspected the access management controls for the DocBits application, hosted at <a href="https://www.docbits.com">www.docbits.com</a> and built with Microservices, FastAPI, and Vue.js, to confirm that access to the Digital Ocean servers is restricted to authorized users within the FELLOWPRO team.</p>                                                                                                                                                                                                                                                                                                       | No Exceptions Noted |

|  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |                                |
|--|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------|
|  | <p>Controls are in place to ensure that account creation, access permissions, and login credentials are managed securely, role based access (RBAC) is configured at code level for each client hosted within a Multi-Tenant architecture.</p>                                                                                                                                                                                                                                                                                                                                                | <p>Verified that designated Admin and User accounts are assigned to each client entity, ensuring controlled access to the application. Reviewed the implementation of Role-Based Access Control (RBAC), configured at the code level within the multi-tenant architecture</p>                                                                                                                                                                                                                                                                                                                                                                             | <p>No Exceptions<br/>Noted</p> |
|  | <p>Client entity data, including invoices, workflows, and other relevant information, is encrypted and stored in PostgreSQL database servers hosted on Digital Ocean.</p> <p>A common database structure is utilized with logical segregation based on the unique Org_ID serving as the primary key for each client entity. This control ensures that client data is segregated to their dedicated account and accessed only by authorized users within each organization.</p>                                                                                                               | <p>Inspected documentation for default data encryption at rest in Digital Ocean. Reviewed the use of a common database structure with logical segregation based on the unique Org_ID as the primary key.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                              | <p>No Exceptions<br/>Noted</p> |
|  | <p>The organization maintains segregation between the Development, Staging, and Production environments within the PostgreSQL database servers hosted on Digital Ocean.</p> <p>Each environment is isolated to ensure that data integrity and security are maintained throughout the development lifecycle, no production data is used in the development or staging environment.</p> <p>No client is granted access to the underlying cloud infrastructure or environment, access to the databases in the cloud are restricted to FELLOWPRO's employees to prevent unauthorized access.</p> | <p>Inspected the environmental segregation controls implemented for the PostgreSQL database servers hosted on Digital Ocean. Verified that the organization effectively maintains isolation between the Development, Staging, and Production environments throughout the development lifecycle.</p> <p>Observed that production data is not utilized in the Development or Staging environments, thereby reducing the risk of exposure. Additionally, reviewed the access controls and confirmed that clients do not have access to the cloud infrastructure; access to the databases is restricted exclusively to authorized employees of FELLOWPRO.</p> | <p>No Exceptions<br/>Noted</p> |

| Payment Integrations |                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                                                                                                                                                                                                                                                                                                                                                                      |                     |
|----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
|                      | The DocBits solution does not handle payment processing or integrations within the product.                                                                                                                                                                                                                                                                                                                                         | Verified that DocBits does not require payment integrations as a part of its project implementation plan.                                                                                                                                                                                                                                                                            | No Exceptions Noted |
|                      | Client payments are handled through invoices with the start of the project implementation. To track and manage payment information, FELLOWPRO uses WeClap, an ERP system that monitors payment status and ensures timely tracking.                                                                                                                                                                                                  | The WeClap interface being used for managing payment information as an ERP system was inspected.                                                                                                                                                                                                                                                                                     | No Exceptions Noted |
| Training and Support |                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                                                                                                                                                                                                                                                                                                                                                                      |                     |
|                      | FELLOWPRO has Application documentation which is accessible to clients via <a href="https://docs.docbits.com">https://docs.docbits.com</a> that provides structured training to clients on the effective use of its Intelligent Document Processing (IDP) platform - DocBits.                                                                                                                                                       | Inspected and confirmed that the application documentation at <a href="https://docs.docbits.com">https://docs.docbits.com</a> is shared to the client during their engagement.                                                                                                                                                                                                       | No Exceptions Noted |
|                      | The organization has implemented training documentation for DocBits dashboard which covers dashboard manuals for users to monitor and manage document workflows. Through this documentation the clients are trained to use features like document tracking, filtering, and validation. This ensures proper oversight of document handling processes, reducing the risk of errors and improving the accuracy of financial reporting. | Inspected the Dashboard training landing page at <a href="https://docs.docbits.com/readme-1/dashboard">https://docs.docbits.com/readme-1/dashboard</a> Confirmed that FELLOWPRO provides this training documentation to the client to ensure proper oversight of document handling processes, thereby reducing the risk of errors and enhancing the accuracy of financial reporting. | No Exceptions Noted |

|  |                                                                                                                                                                                                                                                                                                                                                                                      |                                                                                                                                                                                                                                                                                                                                                                                                                                                         |                                |
|--|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------|
|  | <p>The organization utilizes the Zammad help desk tool to manage client support tickets. Clients are instructed to submit support requests via designated email addresses, such as support@docbits.com for general issues and sales@docbits.com for finance-related matters. These tickets are tagged and documented on Zammad dashboard.</p>                                        | <p>Inspected the tickets on Zammad help desk tool for managing client support. Verified that clients are instructed to submit support requests through designated email addresses, such as support@docbits.com for general inquiries and sales@docbits.com for finance-related matters. Confirmed that all support tickets are properly tagged and documented on the Zammad dashboard, ensuring effective tracking and management of client issues.</p> | <p>No Exceptions<br/>Noted</p> |
|  | <p>All client support tickets submitted through Zammad help desk are categorized based on the type and complexity of the issue raised. Once categorized, the tickets are assigned to the appropriate support teams for resolution.</p> <p>The Customer Support team communicates expected Turnaround Time (TAT) to clients based on the type and complexity of the issue raised.</p> | <p>Reviewed sample client support tickets submitted via Zammad, confirming that tickets are classified based on the type and complexity of the issues raised.</p>                                                                                                                                                                                                                                                                                       | <p>No Exceptions<br/>Noted</p> |

#### FELLOWPRO Application Access Controls

|  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |                            |
|--|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|
|  | <p>Clients are provided DocBits Admin and User Accounts.</p> <p><b>Admin Accounts:</b> The Administrative account has following permissions:</p> <ul style="list-style-type: none"> <li>• <b>Workflow Management:</b> Admins can create and customize workflows based on client-specific requirements.</li> <li>• <b>User and Group Management:</b> They can create, group, and assign permissions to users based on roles.</li> <li>• <b>Settings Control:</b> Admins have full control over configuration settings, including integrating external tools like Power BI etc.</li> <li>• <b>Permissions Assignment:</b> They define user permissions, including access levels and actions allowed within the application.</li> </ul> <p><b>User Accounts :</b> These accounts are managed by Client entity employees for:</p> <ul style="list-style-type: none"> <li>• <b>Workflow Execution:</b> Users operate within predefined workflows, such as processing tasks and approving invoices.</li> <li>• <b>Dashboard Access:</b> Users can view and interact with the product dashboard but are limited by the permissions assigned by the admin.</li> </ul> | <p>Inspected the Group and Permission module on DocBits application to confirm user groups and permissions can be assigned to user accounts, this can only be done by Admin account.</p> <p>Observed that within the access configuration screen, users can be granted specific permissions by the Account Admin—such as View, Update, Delete, First Approval, or Second Approval—based on their role and responsibility within the organization.</p> <p>Sample of Client defined Workflows for documenting payslips, financial statements etc was evidenced.</p> | <p>No Exceptions Noted</p> |
|--|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|

## SECTION 5

### OTHER INFORMATION PROVIDED BY FELLOWPRO



## Other Information Provided by FELLOWPRO

The information provided in this section is provided for informational purposes only by FELLOWPRO. Independent Auditor has performed no audit procedures in this section.

### Disaster and Recovery Services

The AICPA has published guidance indicating that business continuity planning, which includes disaster recovery, is a concept that addresses how an organization mitigates future risks as opposed to actual controls that provide user auditors with a level of comfort surrounding the processing of transactions.

In addition to the physical controls, FELLOWPRO has implemented logical controls to safeguard against interruption of service. FELLOWPRO has developed a number of procedures that provide for the continuity of operations in the event of an availability zone failure by spinning up multiple servers across all availability zones.

The disaster recovery plan defines the roles and responsibilities and identifies the critical IT application programs, operating systems, personnel, data files, and time frames needed to ensure high availability and system reliability based on a business impact analysis.

# CERTIFICATE *of* SIGNATURE

REF. NUMBER  
VD7B8-NRKDG-4DAHT-LDJDD

DOCUMENT COMPLETED BY ALL PARTIES ON  
26 FEB 2026 08:09:00  
UTC

## SIGNER

**DANIEL JORDAN**

EMAIL  
DANIEL.JORDAN@FELLOWPRO.COM

## TIMESTAMP

SENT  
25 FEB 2026 13:34:31

VIEWED  
26 FEB 2026 08:08:48

SIGNED  
26 FEB 2026 08:09:00

## SIGNATURE

*Daniel Jordan*

IP ADDRESS  
93.240.25.177

LOCATION  
BERLIN, GERMANY

## RECIPIENT VERIFICATION

EMAIL VERIFIED  
26 FEB 2026 08:08:48

